

HYUNDAI MOTOR · 차량사이버보안개발팀

Day 5

Integrated Security PoC · 최종 리뷰

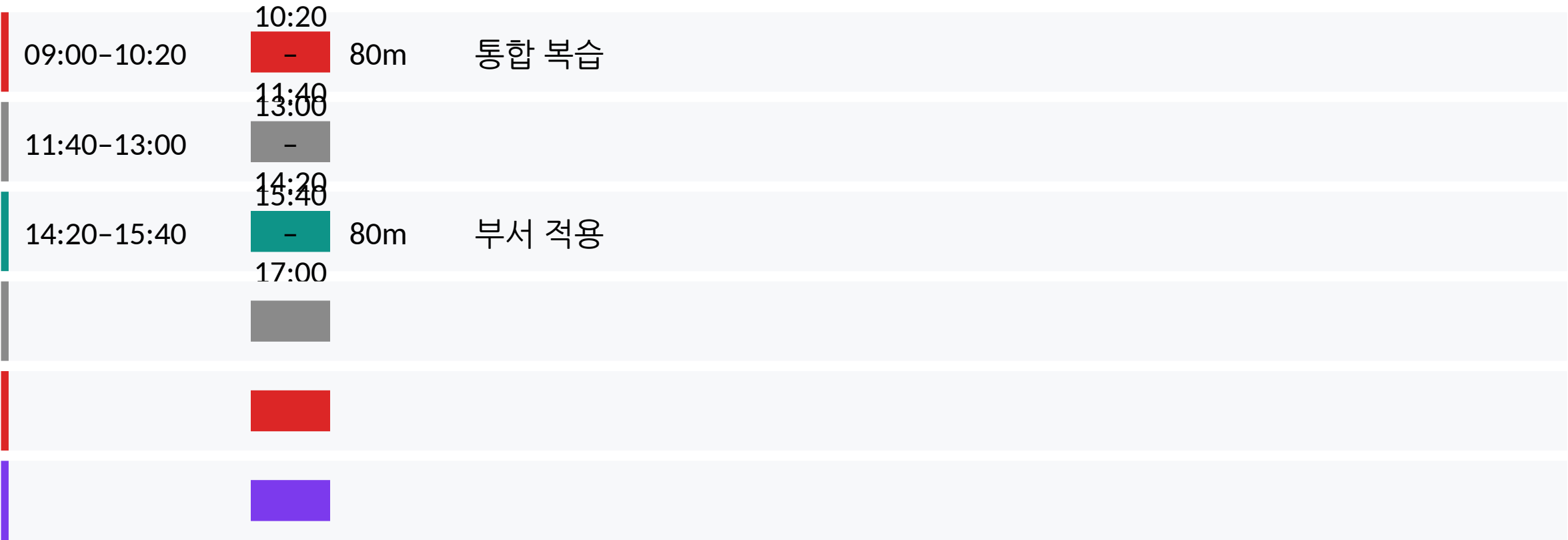
통합 운영자료 (개념+실습 병행) · 6/12 金 · 09:00–17:00

5일간의 모든 요소를 한 파이프라인으로 실행하고, final_report.md를 만들어 발표한다.

이 파일 하나를 하루 수업을 끝까지 진행합니다. 상세 이혼은 *Appendix*를 참조하세요.

Day 5 운영 흐름

5일간의 모든 요소를 한 파이프라인으로 실행하고, final_report.md를 만들어 발표한다.



Day 5 — 무엇을 배우고 무엇을 만드는가

학습 목표·실습 목표·사용 파일·성공 기준을 시작 전에 못 박아 둡니다.

학습 목표 (개념·실습 병행)

- 통합 파이프라인의 전체 구조
- 방어 방안 제안 작성법
- 부서 적용을 위한 점진 도입 전략

실습 목표 (실습·산출물 확인)

- 통합 실행(--hitl --threat-intel --report final)
- final_report.md 생성·해석
- 팀별 발표·상호 리뷰

사용 파일

- orchestrator/supervisor_graph.py (전체)
- reports/final_report.md
- reports/risk_score_table.md

성공 기준

- 통합 실행 성공
- 위험도 점수표 포함 final_report 생성
- 발표 5개 항목 충족

Day 5

5일 로드맵: 단일 Agent에서 통합 Security PoC까지

오늘이 전체 과정에서 어디에 위치하는지 먼저 확인합니다.

단일 Agent에서 통합 Security PoC까지 이어지는 하나의 파이프라인입니다.



① 개념 설명 → ② 파일 확인 → ③ 직접 실행 → ④ 산출물 확인 → ⑤ 관찰 정리 → ⑥ 다음 연결

개념 + 실습 병행 운영 패턴 (09:00-17:00)

개념을 설명하고 바로 파일 확인·실행·산출물 검증으로 이어갑니다.

수업은 이론을 몰아서 듣는 방식이 아니라, 작은 학습 루프를 하루에 3회 이상 반복합니다.



매일 최소 3회 이상 직접 실행



운영 메모: TDD/Review Loop 관점: 최종 보고서도 검증 기준을 통과해야 운영 산출물로 인정한다.

오늘의 자료 구조: PPT → 코드 → 명령 → 산출물

수강생이 지금 보는 장표가 어떤 파일과 어떤 결과물로 이어지는지 명확히 보여줍니다.

PPT의 개념은 실제 Codespaces 파일·명령어·산출물로 바로 연결되어야 합니다.



PPT 개념

통합 Security PoC

Final Report · Remediation
· Audit Trail

확장 개념
Delivery, Remediation Plan,
Department Adoption



관련 파일

orchestrator/supervisor_graph.py

reports/final_report.md

reports/risk_score_table.md

memory/audit_log.jsonl



실행 명령

```
python orchestrator/supervisor_graph.py --target  
sample_app/ --hitl --threat-intel --report final
```



산출물

reports/final_report.md

reports/risk_score_table.md

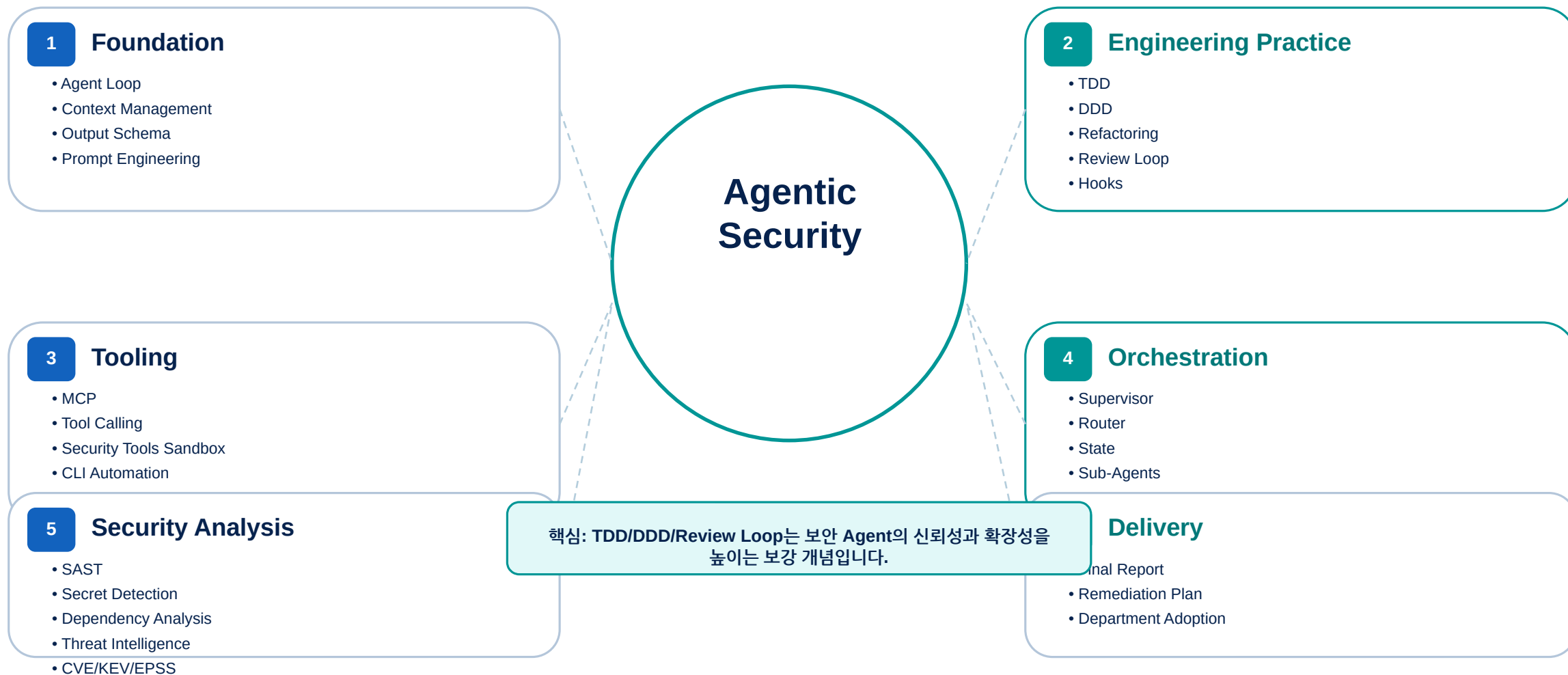
reports/threat_context.json

memory/audit_log.jsonl

보강 개념 맵: 에이전틱 보안 엔지니어링

TDD·DDD·Review Loop·Hooks 등은 현재 실습 흐름을 보강하는 개념으로 연결합니다.

오늘 핵심 개념을 보안 실습 흐름에 맞춰 정리한 장입니다.



이 그림은 오늘의 핵심 구조를 파일·실행·산출물 관점으로 연결합니다.



Mini Lab → Main Lab 연결

작은 실험으로 개념을 먼저 체감하고, 바로 보안 실습으로 확장합니다.

Mini Lab · Department Adoption Canvas

Policy
Tools
HITL Criteria
Audit Location

Main Lab · Integrated Security PoC

Final Report
Remediation
Quality Gate
Department Adoption

연결 문장

final_report.md는 끝이 아니라 현업 적용의 시작입니다. 정책·도구·HITL·Audit 기준을 부서 맥락으로 옮깁니다.

Mini Lab 실행 · Department Adoption Canvas

한 줄 명령으로 실행하고, 산출물을 확인합니다.

왜 하는가

최종 PoC 산출물을 부서 운영 기준으로
바꿔 실제 적용 계획을 만듭니다.

```
cp course/department_adoption_canvas.md reports/department_adoption_canvas.md
```

관련 파일

course/department_adoption_canvas.md
reports/final_report.md
reports/risk_score_table.md

생성 산출물

reports/department_adoption_canvas.md

확인 포인트

정책 위치
도구 MCP화 후보
승인/감사 기준

Quality Gate · Review Loop · Operationalization

부가 개념을 키워드가 아니라 실습·산출물·검증과 연결합니다.

Quality Gate

최종 보고서도 검증 대상입니다.
누락, 비밀값 노출, 근거 없는 발견은 운영 산출물이 될 수 없습니다.

Review Loop

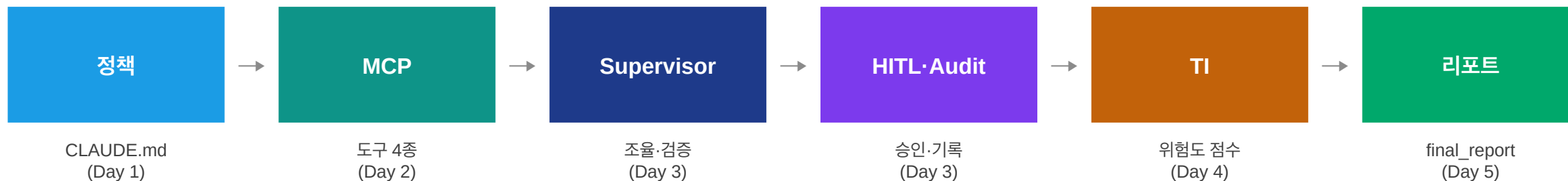
final_report.md를 사람이 검토하고, 부족하면 보완합니다.
자동화 결과도 리뷰를 통과해야 합니다.

Operationalization

전면 자동화가 아니라 작은 범위에서 시작합니다.
정책·도구·승인·감사 기준을 차례로 확장합니다.

5일이 한 번의 실행에 모두 참여한다

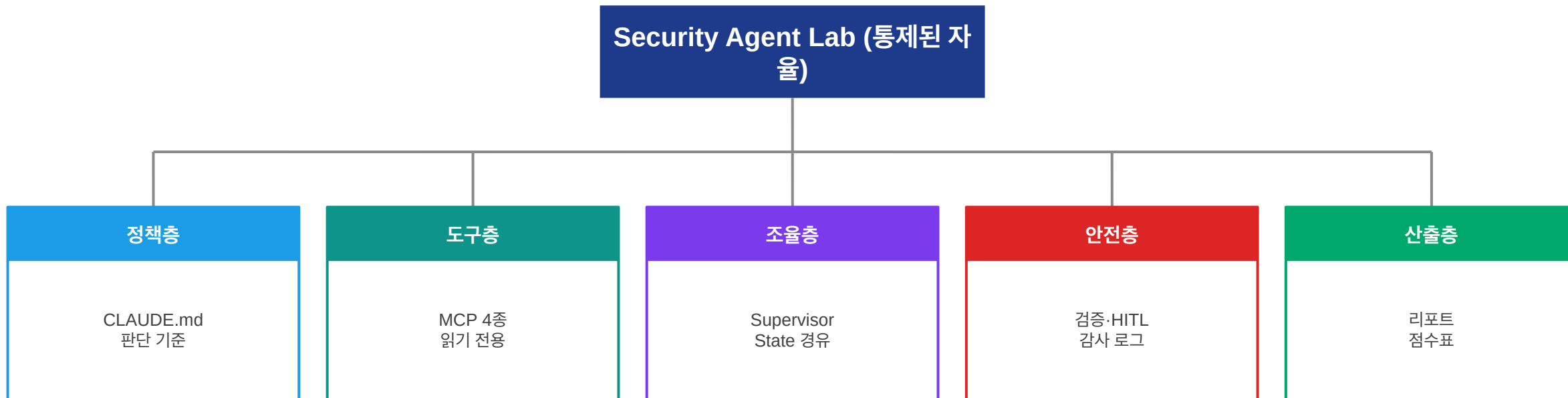
각 Day의 산출물이 통합 실행의 한 단계로 들어갑니다. 따로 배운 것들이 하나로 이어집니다.



오늘은 새 개념을 배우지 않습니다. 나흘간 만든 부품들이 하나의 완성된 시스템으로 작동하는 것을 확인합니다.

그림으로 보는 전체 아키텍처 — 다섯 층의 탑

5일간 만든 모든 부품을 하나의 층 구조로 쌓아 봅니다. 발표 자료의 첫 그림으로 쓰기 좋습니다.



위층은 아래층 없이 서지 못합니다. 정책 없는 도구는 방향이 없고, 안전장치 없는 조율은 신뢰가 없습니다. 이 의존 관계가 곧 도입 순서입니다.

그림으로 보는 5일 누적 — 한 층씩 쌓아 올린 PoC

통합 PoC는 갑자기 만들어진 것이 아니라, 나흘간 한 층씩 쌓은 결과입니다. 각 날이 다음 날의 토대가 됩니다.



아래층 없이 위층은 서지 못합니다. 이 누적 순서가 곧 부서에 도입할 때의 순서이기도 합니다 — 작게 쌓아 올립니다.

오늘 하루가 하는 일 — 한눈에

목표·준비물·사용 파일·성공 신호입니다.

목표

- 전체 파이프라인 통합 실행
- final_report.md 생성·발표

준비물

- Day 1~4 모든 산출물
- 수정한 정책·가중치

사용 파일

- supervisor_graph.py (전체)
- reports/ 산출물

성공 신호

- 통합 실행 성공
- 발표 5항목 충족

통합 PoC 실행 — 모든 플래그를 켜다

오늘의 핵심 명령입니다. 정책·도구·조율·HITL·위협정보가 한 번에 작동합니다. ZIP 명령과 1:1 일치.

통합 실행

```
python orchestrator/supervisor_graph.py --target sample_app/ \
  --hitl --threat-intel --report final
```

생성 산출물

reports/final_report.md	(확정/반려 분리 + 점수표)
reports/risk_score_table.md	(HITL 상태 컬럼 포함)
reports/threat_context.json	(위협 컨텍스트)
memory/audit_log.jsonl	(전 과정 결정 기록)

이 한 줄이 5일의 결정체입니다. 각 플래그(--hitl, --threat-intel)가 어느 Day에서 왔는지 떠올려 보세요.

통합 PoC 성공 기준 — 네 가지

통합 실행이 '성공'했다고 말하려면, 단순히 에러 없이 끝나는 것 이상이 필요합니다.

①

탐지율 기록

정답지 대비 몇 종을 탐지했는지 기록합니다. vulnerability.py 9종 중 8종 + control/ 1건이 기준입니다.

②

HITL 통과

High 이상 발견이 모두 HITL 게이트를 거쳤는지 확인합니다. 비대화형이면 모두 반려로 기록됩니다.

③

Provenance 완비

모든 발견에 출처(provenance)가 붙어 있는지 봅니다. 출처 없는 발견은 신뢰할 수 없습니다.

④

점수표 포함 리포트

final_report.md에 위험도 점수표가 포함되고, 확정/반려가 분리되어 있는지 확인합니다.

통합 실행을 단계별로 따라가기

통합 실행이 한 번에 끝나는 것처럼 보이지만, 내부에서는 5일치 단계가 순서대로 작동합니다.

콘솔 출력 (전체 흐름)

```
[Supervisor] 점검 시작 - hitl=True TI=True
[router]    route=[sast, secret, deps, threat, report] ← Day 3
[sast]      정책 CLAUDE.md 적용 분석 ← Day 1
[deps]      CVE 4건 추출 → State ← Day 2 도구
[threat]    KEV·EPSS 조회 → threat_context.json ← Day 4
[hitl]      High 이상 승인 대기 (비대화형=반려) ← Day 3
[report]    final_report.md 생성 ← Day 5
```

각 로그 줄 옆에 어느 Day에서 배운 것인지 표시했습니다. 5일이 한 흐름으로 합쳐지는 모습을 눈으로 확인하세요.

통합 실행이 막히면 — 단계별 점검

통합은 여러 단계가 맞물려 있어, 어느 단계가 비었는지 거꾸로 짚어야 합니다.

①

점수표가 비어 있다

--threat-intel 플래그가 빠졌거나, deps가 CVE를 못 넘긴 경우입니다. threat_context.json이 생성됐는지 먼저 봅니다.

②

리포트에 확정이 없다

비대화형 실행이면 High 이상이 모두 반려됩니다. 정상입니다. '반려·보류' 섹션을 확인합니다.

③

일부 발견이 누락

Day 1~4 산출물이 모두 있는지 확인합니다. 통합은 앞 단계 산출물에 의존합니다.

방어 방안 실습

실습 — 방어 방안 제안과 부서 적용

점검 결과를 '발견 목록'에서 '실행 가능한 방어 계획'으로 바꿉니다.

final_report를 방어 방안으로 발전시키기

리포트는 끝이 아니라 시작입니다. 발견 각각에 '무엇을 할 것인가'를 붙입니다.

①

우선순위 확정

위험도 점수표 상위부터 대응 순서를 정합니다. pyyaml 같은 KEV 등재 항목이 먼저입니다.

②

대응 방안 매칭

각 발견에 구체적 조치를 답니다(예: pyyaml 버전 업그레이드, SQL 파라미터 바인딩 적용).

③

잔여 위험 명시

당장 못 고치는 것은 '수용한 위험'으로 기록합니다. 침묵이 아니라 명시적 결정으로 남깁니다.

부서 도메인 적용 — 점진 도입 3단계

이 교육용 키트를 실제 부서 업무로 옮기는 현실적 경로입니다.

1단계 정책화
우리 팀의 점검 기준을 CLAUDE.md로 옮깁니다. 가장 작고 안전한 시작입니다(Day 1에서 배운 것).

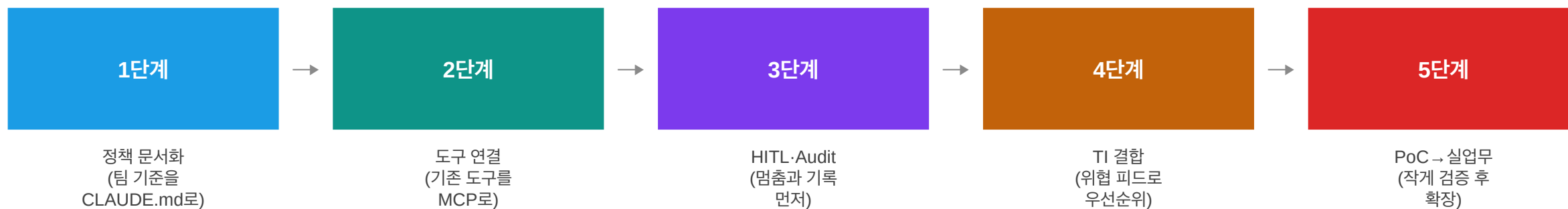
2단계 도구·안전장치 도입
기존 보안 도구를 MCP로 묶고, HITL·감사 로그를 붙입니다(Day 2~3). 자동화에 통제를 먼저 심습니다.

3단계 통합·확대
위협 정보를 결합하고 파이프라인을 통합합니다(Day 4~5). 작게 검증한 뒤 점진적으로 넓힙니다.

원칙: 작게 시작 → 검증 → 확장. 처음부터 전면 자동화를 시도하지 않습니다. 통제 가능한 범위에서 신뢰를 쌓아 갑니다.

그림으로 보는 현업 적용 로드맵 — 다섯 단계

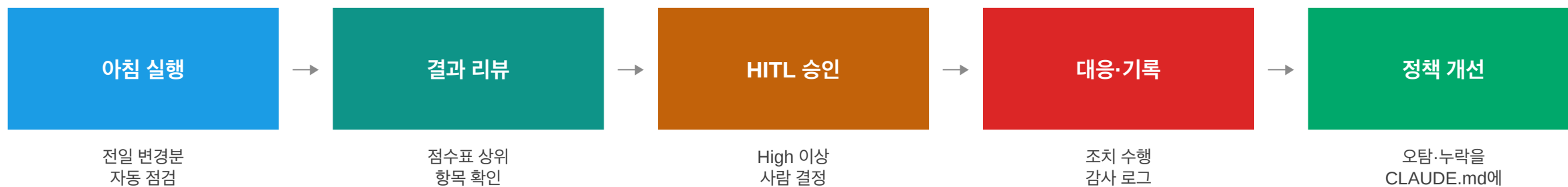
이 키트를 부서 업무로 옮기는 현실적 순서입니다. 5일의 학습 순서가 곧 도입 순서입니다.



순서가 핵심입니다. 안전장치(3단계) 없이 4·5단계로 가지 않습니다. 전면 자동화가 아니라 작게 시작해 검증하며 넓힙니다.

그림으로 보는 일일 운영 — 도입 후의 하루

부서에 도입했다고 가정할 때, 이 시스템이 실제로 돌아가는 하루의 모습을 그려봅니다.



마지막 칸에 주목하세요. 운영에서 발견한 오탐·누락이 정책 개선으로 되먹임되는 순환 — 이것이 시스템이 '자라는' 방식입니다.

팀별 PoC 발표 — 다섯 가지를 담는다

실습 후반은 팀별 발표와 상호 리뷰입니다. 다음 다섯 가지를 담으면 충분합니다.

①

파이프라인 데모

통합 실행을 라이브로 보여줍니다. HITL 승인/반려 장면을 반드시 포함합니다.

②

점수표 해설

위험도 상위 2건이 왜 거기에 있는지, 어떤 가중치를 썼는지 설명합니다.

③

정책 결과

CLAUDE.md에 넣은 사내 정책과 그 전후 결과 차이를 보여줍니다.

④

한계와 미점검

탐지율·오탐·미점검 영역(예: CWE-532 누락)을 정직하게 공개합니다.

⑤

부서 적용

우리 팀 업무 중 이 구조를 가장 먼저 이식할 한 곳을 제안합니다.

발표 데모 — 막히지 않게 미리 준비하기

라이브 데모는 강력하지만 위험합니다. 미리 준비해 발표 중 멈추지 않게 합니다.

①

사전 1회 실행

발표 직전에 통합 실행을 한 번 돌려, 산출물이 정상 생성되는지 확인합니다.

②

출력 캡처 보관

라이브가 실패할 경우를 대비해, 정상 출력 화면을 미리 캡처해 둡니다.

③

핵심 장면 표시

HITL 승인/반려 장면과 위험도 1순위가 드러나는 부분을 미리 표시해 둡니다.

상호 리뷰 — 무엇을 보고 피드백할까

다른 팀 발표를 들을 때 무엇에 주목할지 미리 정해 두면, 리뷰가 풍부해집니다.

기술 관점

- 탐지율과 누락을 정직하게 공개했나
- 위험도 가중치에 근거가 있나
- HITL·감사가 실제로 작동했나

적용 관점

- 부서 적용 대상이 현실적인가
- 점진 도입 순서가 타당한가
- 우리 팀에도 가져올 만한 아이디어인가

리뷰의 목적은 평가가 아니라 상호 학습입니다. 다른 팀의 부서 적용 아이디어에서 우리 팀의 힌트를 얻습니다.

산출물 미리보기 — final_report.md 구조

통합 실행의 최종 산출물입니다. 위험도 점수표, 확정 발견, 반려/보류 발견이 분리되어 담깁니다.

reports/final_report.md (구조)

```
# 통합 보안 점검 리포트
총 발견: N건 (확정 X / 반려·보류 Y) · 위협 CVE: Z건

## 위험도 점수표
| 순위 | 발견 | 심각도 | HITL 상태 | CVE | 위험도 |

## 확정 발견 (대응 대상)
- [심각도] 발견 · 근거(마스킹) · 출처 · 위험도
## 반려·보류 발견 (HITL 미승인)
- [심각도] 발견 (HITL 반려/보류)
```

위험도 순위(우선순위 권고)와 HITL 상태(대응 승인 여부)가 다른 축임을 한 문서 안에서 분리해 보여줍니다.

5일 과정 종합 회고

5일간 무엇을 만들었고, 무엇을 가져갈지 정리합니다.

5일간 만든 것

- 정책에 통제되는 SAST (Day 1)
- MCP로 표준화한 도구 (Day 2)
- 조율·검증·감사 (Day 3)
- 위협 정보·위험도 (Day 4)
- 통합 PoC (Day 5)

핵심 메시지

- 목표는 자율이 아니라 '통제된 자율'
- 도구는 사실을, LLM은 의미를
- 멈춤과 기록이 신뢰를 만든다
- 작게 시작해 검증하며 넓힌다

이 과정의 목표는 개별 기술 습득이 아니라 '하네스로 통제되는 보안 자동화 에이전트를 설계하는 눈'입니다.

5일 과정 전체 지도 — 무엇을 만들었나

다섯 날의 산출물과 핵심 개념을 한 표로 정리합니다. 복습과 부서 공유에 쓰세요.

Day	주제	핵심 산출물	하네스 연결
1	Security by Design	lab1_sast.md · CLAUDE.md	요소① 프롬프트
2	MCP 도구 자동화	MCP 등록 · 도구 4종	요소④ 도구
3	Orchestration·HITL	lab3_report · audit_log	요소②⑤ 루프·안전장치
4	Threat Intelligence	threat_context · 점수표	요소③ 컨텍스트
5	통합 DeC	final_report.md	요소① 통합

5일 내내 같은 하네스 5요소가 돌아왔습니다. 각 Day는 그 중 한 요소를 코드와 정책으로 깊이 다룬 것입니다.

5일 과정 — 최종 이해 점검

여기까지 이해했는지 스스로 점검해 봅니다.

- ☒ 하네스 5요소를 모두 설명할 수 있다
- ☒ MCP로 도구를 표준 연결하는 법을 안다
- ☒ Supervisor·검증·HITL·감사의 역할을 구분한다
- ☒ CVE·KEV·EPSS로 우선순위를 정할 수 있다
- ☒ 통합 PoC를 실행하고 결과를 해석할 수 있다
- ☒ 부서 적용 3단계를 제안할 수 있다

여섯 가지에 모두 답할 수 있다면, 이 과정의 목표인 '통제된 자동화를 설계하는 눈'을 갖춘 것입니다.

Day 5 — 오늘 만든 산출물 확인

오늘 저장소에 실제로 남은 것들입니다. 다음 Day의 입력으로 누적됩니다.

01

reports/final_report.md

위험도 점수표·HITL 상태·Provenance가 담긴 최종 점검 리포트

02

부서 적용 구상

팀별로 도출한 첫 이식 대상과 점진 도입 계획

이 과정의 목표는 '하네스로 통제되는 보안 자동화 에이전트 구축'입니다. final_report.md가 그 증명입니다.

Day 5 — 자주 나는 오류

강의장에서 가장 흔히 막히는 지점과 즉시 대응법입니다.

통합 실행 일부 단계 누락

→ Day 1~4 산출물 존재 여부 확인

final_report에 점수표 없음

→ --threat-intel 플래그 누락 확인

반려 발견이 대응 대상에 섞임

→ 리포트의 'HITL 상태' 컬럼으로 확정/반려 구분

전반적으로 느림

→ Codespace 사양·병렬 실행 여부 확인

Day 5 — 완료 체크리스트 · 다음 Day 연결

체크리스트로 마감하고, 내일로 이어지는 연결고리를 확인합니다.

☒ 통합 실행 성공

☒ final_report.md 생성

☒ 위험도 점수표 포함 확인

☒ 확정/반려 발견 구분 확인

☒ 발표 5개 항목 준비

☒ 부서 적용 대상 1곳 선정

다음 Day 연결고리 → 과정 종료 — 통제된 자동화를 설계하는 눈을 부서 실무로 이식한다

APPENDIX

부록 — 이론 상세 보충

본문에서 압축한 개념의 상세 설명입니다. 수업 중 질문이 나오거나, 복습 시 참조하세요.

[상세] 실무 도입 5대 리스크

부서 적용 시 처음부터 설계해야 할 위험들입니다.

① 권한

과도한 권한

에이전트에 필요 이상의 권한을 주면 사고 시 피해가 큼. 읽기 전용·최소 권한이 기본입니다.

② 데이터

민감 정보 유출

점검 대상에 비밀·고객 데이터가 섞일 수 있습니다. 마스킹·외부 전송 통제가 필수입니다.

③ 비용

토큰·실행 비용

루프와 재시도가 비용을 키웁니다. 상한과 모니터링이 필요합니다.

④ 조정

오케스트레이션 복잡도

Agent가 늘수록 조율이 어려워집니다. 중앙 통제와 단순한 구조를 유지합니다.

⑤ 재현성

결과 변동

LLM 해석은 변동할 수 있습니다. 도구 원본 보존과 검증 루프로 재현성을 확보합니다.

[상세] 자율성과 거버넌스의 균형

본 과정 전체를 관통하는 철학입니다.

자율성

에이전트의 힘

스스로 판단하고 도구를 쓰는 능력. 생산성의 원천이지만, 통제 없으면 위험의 원천이기도 합니다.

거버넌스

통제의 틀

정책·검증·HITL·감사. 자율성을 안전하게 끌어내는 울타리입니다.

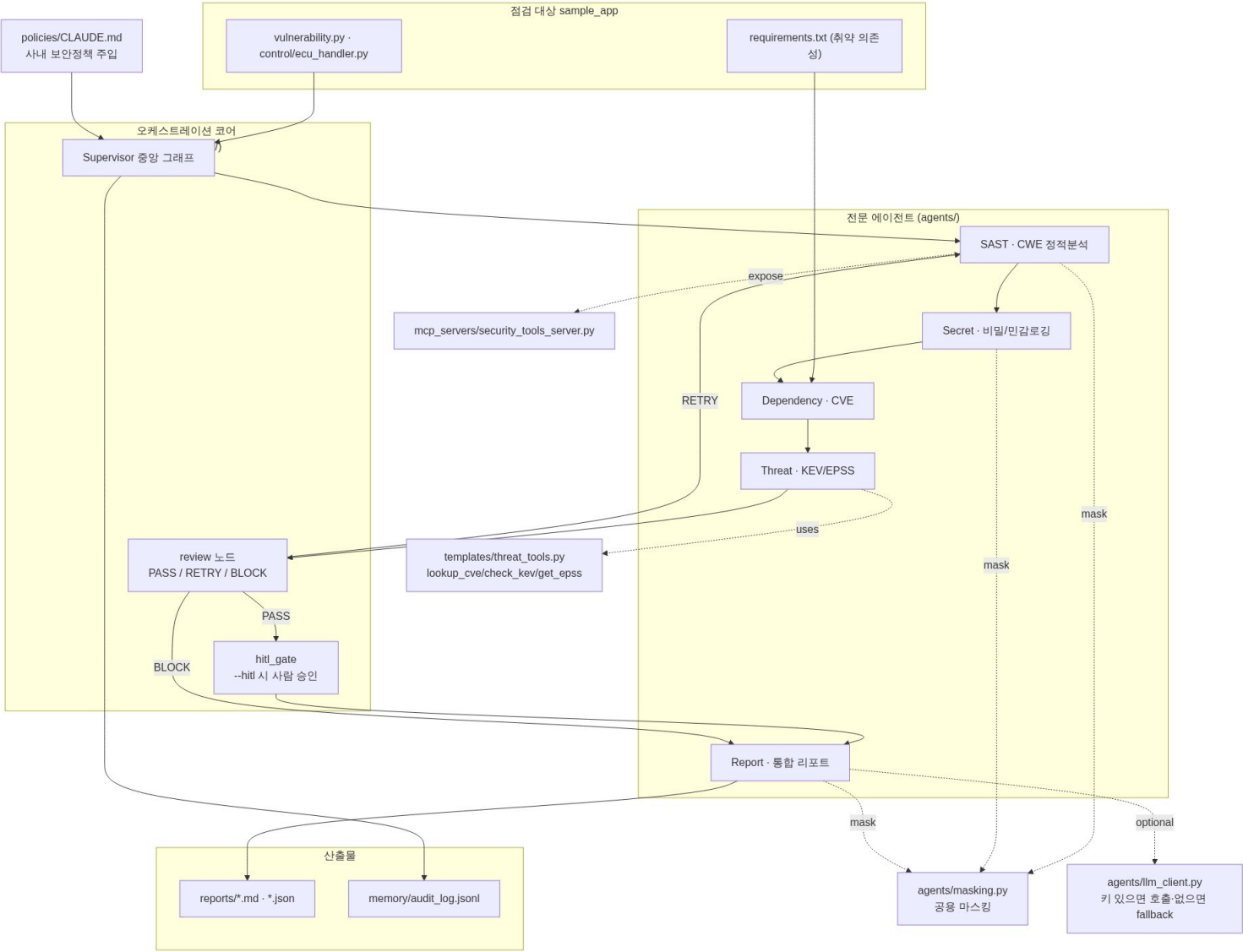
균형

통제된 자율

둘 중 하나를 버리는 것이 아니라, 자율성을 거버넌스 안에 두는 것. 이것이 하네스 엔지니어링의 본질입니다.

차량 사이버보안처럼 안전이 직결된 영역일수록, 자율성보다 거버넌스를 먼저 설계해야 합니다.

전체 아키텍처 — Security Agent Lab



Day 5 동작 흐름 (시퀀스 다이어그램)

